Cátedra Redes de Datos

INTRODUCCIÓN A LA SEGURIDAD EN LAS REDES

2026

Concepto de Seguridad

- La seguridad de las redes es ahora una parte integral de las redes informáticas.
- Incluye protocolos, tecnologías, dispositivos, herramientas y técnicas que aseguran los datos y reducen las amenazas.

Políticas de Seguridad

- Definiciones:
  - Documento que trata las restricciones y comportamientos de los miembros de una organización y especifica cómo se puede acceder a los datos y quién puede acceder a qué datos
  - Declaración formal de las **reglas** a las cuales deberán atender las personas que tienen acceso a los bienes tecnológicos y de información de una organización

Políticas de Seguridad

CARACTERÍSTICAS:

- Documento diseñado para ser aplicable a las operaciones de una organización
- Utilizado para asistir en el diseño de la red, transmitir principios de seguridad y facilitar el despliegue de la red
- Traza las reglas de acceso a la red
- Determina cómo se harán cumplir las políticas

Políticas de Seguridad

CARACTERÍSTICAS (continuación):

- Documento complejo diseñado para gobernar temas como acceso a los datos, navegación en la web, uso de las contraseñas, criptografía y adjuntos de correo electrónico
- Establece una jerarquía de permisos de acceso y da a los empleados sólo el acceso mínimo necesario para cumplir con sus funciones
- Establece cuáles bienes deben protegerse y cómo deben ser protegidos
- Es un documento vivo, se actualiza constantemente

Políticas de Seguridad

Aspectos a tener en cuenta en el desarrollo de las políticas:

- Necesidades de la empresa
- Identificación de amenazas
- Análisis de riesgos (relación costo-beneficio)
- Necesidades de seguridad
- Prácticas recomendadas por la industria
- Operaciones de seguridad

Documentos que componen una política corporativa

- **Uso aceptable:** qué puede hacer el empleado con correo, Internet y equipos
- **Gestión de accesos:** alta, baja y revisión periódica de permisos; mínimo privilegio
- **Contraseñas y MFA:** longitud mínima, gestor de contraseñas, segundo factor obligatorio
- **Clasificación de la información:** pública, interna, confidencial, restringida
- **Dispositivos móviles (BYOD)** y **teletrabajo**
- **Copias de respaldo:** regla 3-2-1-1 (3 copias, 2 medios distintos, 1 fuera del sitio, 1 inmutable u offline)
- **Respuesta a incidentes** y **continuidad del negocio**
- **Uso de IA generativa:** qué datos no pueden ingresarse en herramientas como ChatGPT o Copilot

Requisitos de una Comunicación Segura

- Confidencialidad → la información debe ser accedida solamente por partes autorizadas
- Integridad → los elementos pueden ser modificados sólo por partes autorizadas
- Disponibilidad → los elementos deben estar disponibles para las partes autorizadas
- Autenticación → verificar la identidad de un usuario o equipo
- No repudio → no poder negar algo que hice

Tipos de Amenazas a la Seguridad

- Interrupción → ataque a la disponibilidad
- Interceptación → ataque a la confidencialidad
- Modificación → ataque a la integridad
- Invención → ataque a la autenticidad

Amenazas actuales en las empresas

- **Ransomware con doble extorsión:** cifra los datos (disponibilidad) y amenaza con publicarlos (confidencialidad)
- **Phishing y fraude BEC (Business Email Compromise) ("fraude del CEO"):** suplantan a un directivo o proveedor para desviar pagos (autenticidad)
- **DDoS:** en septiembre de 2025 Cloudflare mitigó un ataque récord de 22,2 Tbps (disponibilidad)
- **Robo de credenciales:** malware "infostealer" y venta de accesos en foros clandestinos
- **Explotación de equipos de borde:** VPN, firewalls y routers sin parchear
- **Cadena de suministro:** se compromete a un proveedor para llegar a sus clientes

Casos reales: Argentina

- **PAMI (2023):** ransomware Rhysida; el organismo no pagó el rescate y los atacantes publicaron datos de afiliados
- **Comisión Nacional de Valores:** ransomware del grupo Medusa, con pedido de rescate de USD 500.000 en Bitcoin
- **RENAPER (2021):** filtración de datos personales obtenidos con credenciales válidas de un organismo autorizado a consultar la base
- Argentina figura entre los países de la región con mayor cantidad de ciberataques
- **Impacto:** interrupción de trámites, exposición de datos personales y costo reputacional

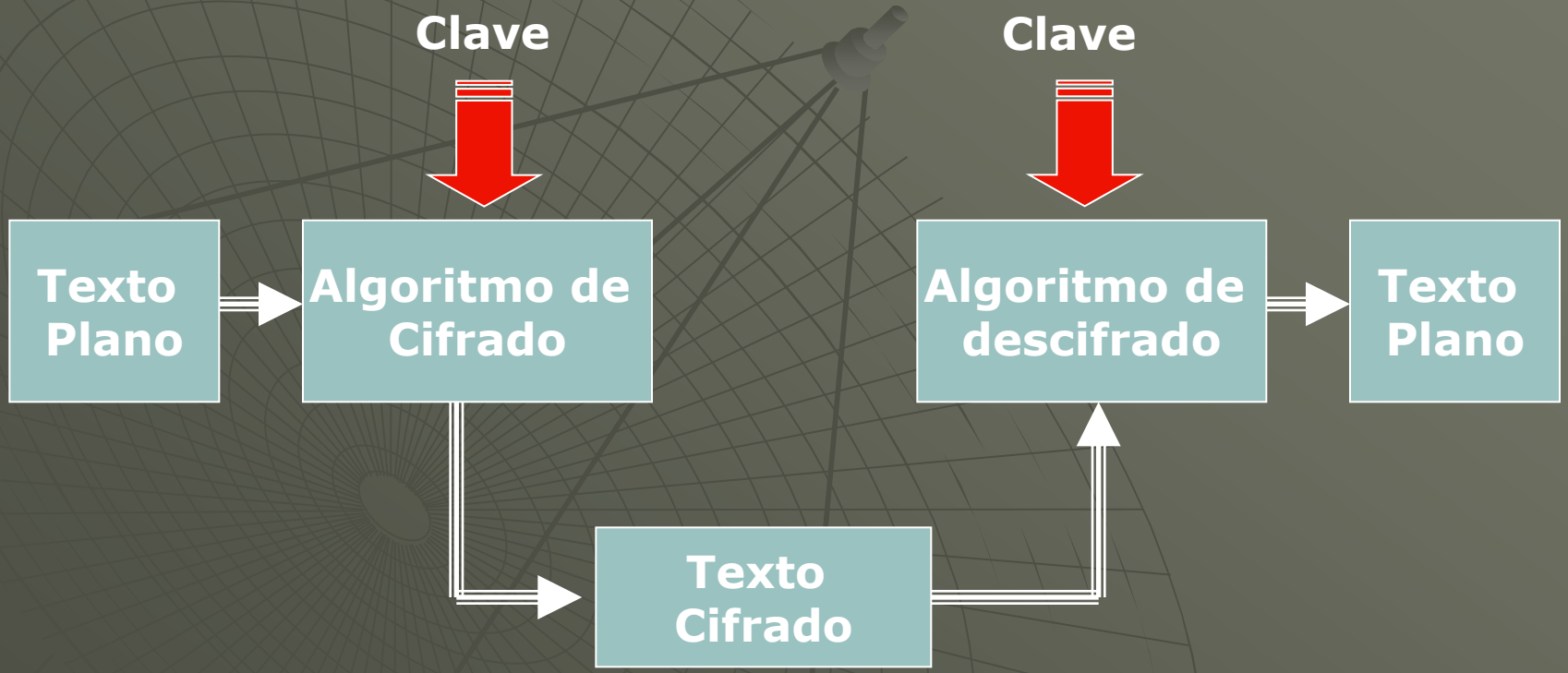
Confidencialidad

- Concepto: asegurar que la información no se revele a personas no autorizadas y que se protejan los datos transmitidos contra ataques pasivos, como la interceptación
- Solución: cifrar la información, datos, voz, video o su combinación.
- Requiere un algoritmo de encriptación y un esquema de administración de claves.

Técnicas criptográficas

- La encriptación es un método para transformar un texto plano a texto cifrado, con la posibilidad de recuperar luego el texto plano a partir del texto cifrado.
- Se implementa a través de un algoritmo de encriptación, que depende principalmente de un parámetro denominado clave.

Proceso de Encriptación



Tipos de Sistemas Criptográficos

Según la cantidad de claves utilizadas:

- Simétricos o de clave privada
  - Emisor y receptor utilizan la misma clave
- Asimétricos o de clave pública
  - Emisor y receptor utilizan diferente clave

Algoritmos: qué se usa hoy y qué se retiró

- **Simétricos vigentes:** AES-128/256 (modo GCM), acelerado por hardware (instrucciones AES-NI); ChaCha20-Poly1305 en móviles
- **Retirados:** DES (clave de 56 bits, quebrado por fuerza bruta en 56 horas en 1998); 3DES (retirado por NIST en 2023); RC4 (prohibido en TLS, RFC 7465)
- **Asimétricos vigentes:** RSA de 2048 bits o más y curvas elípticas (ECC: P-256, X25519, Ed25519)
- ECC de 256 bits ofrece seguridad similar a RSA de 3072 bits, con claves y cálculos mucho más livianos
- **Intercambio de claves:** Diffie-Hellman sobre curvas elípticas (ECDHE)

Cifrado en la empresa: ejemplos cotidianos

- **Notebooks corporativas:** BitLocker (Windows) o FileVault (macOS) obligatorios por política; claves de recuperación guardadas en el directorio
- **Bases de datos:** TDE (Transparent Data Encryption) en SQL Server y Oracle
- **Nube:** servicios de gestión de claves (AWS KMS, Azure Key Vault) respaldados por HSM (Hardware Security Module)
- **Mensajería:** WhatsApp y Signal cifran de extremo a extremo (protocolo Signal)
- **Wi-Fi corporativo:** WPA3 / WPA2-Enterprise
- **Bancos:** los PIN de tarjetas sólo se manejan dentro de HSM (Hardware Security Module)

Autenticación

- Autenticación → garantiza que el mensaje proviene del origen del que dice provenir
- Forma parte de AAA
  - Autenticación → Verificar la identidad digital del remitente de una comunicación
  - Autorización → proceso por el cual la red autoriza al usuario identificado a acceder a determinados recursos del sistema
  - Auditoría → registrar todos los accesos a los recursos que realiza el usuario previamente autorizado

Autenticación en las redes corporativas

- **RADIUS:** servidor AAA central para Wi-Fi corporativo, VPN y acceso remoto
- **TACACS+:** administración de routers y switches; autoriza y registra cada comando ejecutado
- **IEEE 802.1X + EAP-TLS:** el puerto del switch o el Wi-Fi no da acceso hasta que el equipo se autentica con un certificado digital
- **NAC (Network Access Control):** Cisco ISE, Aruba ClearPass, FreeRADIUS; asigna la VLAN según el usuario y el estado del equipo

MFA: autenticación multifactor

- Combina factores: algo que sé (contraseña), algo que tengo (celular, llave), algo que soy (huella, rostro)
- **De menor a mayor resistencia al phishing:** SMS → código TOTP (Google / Microsoft Authenticator) → notificación push con número → FIDO2: llaves de seguridad y passkeys
- **Caso Google:** desde 2017 exige llaves físicas a todos sus empleados → no volvió a registrar cuentas laborales robadas por phishing
- **Caso Uber (2022):** "fatiga de MFA": el atacante envió notificaciones repetidas hasta que el empleado aceptó
- Microsoft estima que MFA bloquea más del 99 % de los ataques automatizados a cuentas

Integridad

- Concepto: consiste en garantizar la exactitud de la información tal cual fue generada, sin ser manipulada o alterada por personas o procesos no autorizados.
- Solución: hash criptográficos

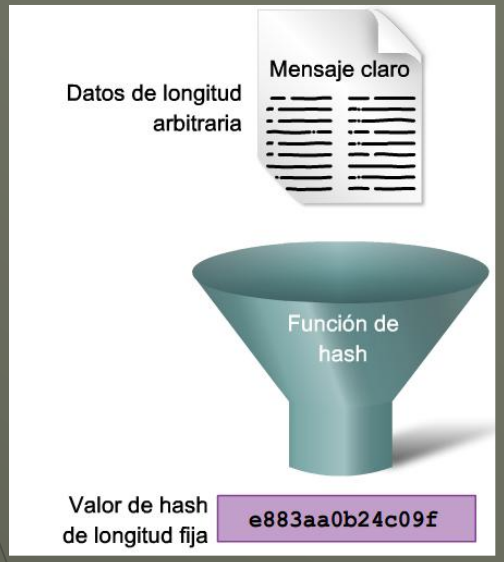
Hash Criptográficos

- Una función de hash produce a partir de un mensaje, una representación del mismo de longitud fija, llamada "digesto de mensaje"
- Es una función matemática de un único sentido
- Dos mensajes diferentes producirán valores de hash distintos
- Utilizada para verificar la INTEGRIDAD de los datos y la AUTENTICACIÓN

Hash Criptográficos

Aplicaciones:
- Verificación de autenticación, junto con una clave secreta (IPsec)
- Autenticación de protocolos de encaminamiento
- Autenticación mediante CHAP
- Verificación de integridad de mensajes

Ejemplos:
- SHA-256 – con hash de 256 bits
- SHA-384 – con hash de 384 bits



Firmas Digitales

- Condiciones que se deben cumplir:
  - Que el receptor pueda verificar la identidad del transmisor
  - Que el emisor no pueda repudiar después el contenido del mensaje
  - Que el receptor no haya podido confeccionar el mensaje él mismo
  - Que no se haya alterado el contenido del mensaje

Firmas Digitales

- Tipos de implementación:
  1. Firmas de clave simétrica (necesidad de un intermediario de confianza, KDC-Key Distribution Center)
  2. Firmas de clave pública (necesidad de una autoridad de certificación, CA-Certification Authority)
  3. Resumen de mensajes (hash)

Firmas Digitales

1. Firmas de clave simétrica:
   - Existe una autoridad central que sabe todo y en quien todos confían (KDC)
   - Cada usuario elige una clave secreta y la entrega personalmente
   - Se utilizan “timestamps” para protegerse ante ataques de repetición
   - Se cifra toda la transacción → se garantiza confidencialidad

Firmas Digitales

2. Firmas de clave pública:
   - RSA es el estándar de facto
   - Se cifra toda la transacción → se garantiza confidencialidad
   - P → texto plano
   - Ana cifra P con su propia clave privada C_A → C_A (P)
   - Luego cifra el resultado con la clave pública de Juan C_J y envía el mensaje
   - Mensaje enviado = C_J (C_A (P))

Firmas Digitales

3. Resumen de Mensajes (hash):
   - No es necesario que la firma digital garantice confiabilidad (firmas de clave simétrica y de clave pública)
   - El SW del firmante aplica un algoritmo sobre el texto obteniendo un extracto de longitud fija 128 – 160 bits. Ejemplo SHA-2 – SHA-3
   - Se cifra el resumen del mensaje - con la clave privada del autor y se añade al final del documento
   - El autor utiliza su propia clave privada y queda vinculado al documento
   - Cualquier persona puede verificar la validez de la firma si dispone de la clave pública del autor

Distribución de Claves Simétricas

- Si Ana necesita intercambiar mensajes confidenciales con N personas, requiere N claves distintas
- Objetivo:
  - Solucionar la gran cantidad de claves diferentes para un gran número de usuarios
  - Distribuir eficientemente las claves entre los usuarios que desean confidencialidad

Centro de distribución de claves

(KDC=key distribution center)

- Entidad de red de confianza con la que se establece el valor de la clave compartida
- Se genera una clave simétrica de sesión entre dos partes que se utiliza SÓLO UNA VEZ
- El KDC tiene una clave simétrica diferente con cada usuario registrado, esta clave se puede instalar manualmente en el servidor cuando el usuario se registra por primera vez
- Ejemplo: kerberos (protocolo y KDC)

Centro de Distribución de Claves

Pasos para generar una clave secreta:

- Ana envía un mensaje encriptado al KDC para comunicarse con Bruno Ka-kdc(A,B)
- El KDC desencripta el mensaje y genera un número aleatorio, R1 (clave de SESION)
- El KDC informa a Ana y a Bruno que utilizarán R1, enviándole el siguiente mensaje:
  - R1, la clave de sesión que utilizarán Ana y Bruno
  - Un par de valores: A y R1, encriptados por el KDC con la clave de Bruno
- El KDC coloca estos elementos en el mensaje, los encripta y se los envía a Ana.
- Ana recibe el mensaje, lo desencripta y extrae R1. Ana conoce ahora la clave compartida.
- Ana le reenvía a Bruno la otra parte del mensaje que le llegó
- Bruno desencripta el mensaje recibido utilizando su clave que tenía con el KDC y extrae A y R1.
- Ahora Bruno conoce la clave de sesión R1 y la persona con quien está compartiendo esa clave, A.

Kerberos en la empresa: Active Directory

- Cada controlador de dominio de Active Directory funciona como KDC
- Al iniciar sesión en Windows el usuario obtiene un TGT (Ticket Granting Ticket), válido por defecto 10 horas
- Con el TGT pide tickets de servicio (servidor de archivos, SQL Server, impresoras) sin volver a escribir la contraseña
- Requiere relojes sincronizados (tolerancia de 5 minutos) → NTP es un servicio crítico
- **Ataques conocidos:** Kerberoasting y Golden Ticket (robo de la clave de la cuenta krbtgt)
- Por eso los controladores de dominio se protegen como activos de máxima criticidad (“Tier 0”)

Distribución de Claves Públicas

Autoridad de certificación (CA-certification authority)

- Utilizado en la criptografía de clave pública
- La autoridad, certifica que una clave pública pertenece a una entidad determinada (a una persona o a una entidad de red)
- Las entidades (usuarios, navegadores y routers) necesitan estar seguros que tienen la clave pública de aquel con quien se están comunicando
- Una Autoridad de Certificación (CA) tiene la responsabilidad de validar identidades y emitir certificados
- Una vez que una CA verifica la identidad de una entidad, crea un certificado que asocia la clave pública con su identidad. El certificado contiene la clave pública y una información que identifica de forma única al poseedor de la clave pública (un nombre o una IP). El certificado es firmado digitalmente por la CA

Firewalls

- Es una combinación de hardware y software que aísla a la red interna de una organización de Internet, permitiendo algunos paquetes y bloqueando otros
- Es un único punto de acceso a la red
- El administrador controla el flujo de tráfico hacia y desde la empresa e Internet

Firewalls

- Tipos de Firewalls:

1. Filtrado de paquetes
2. Firewalls con estado (stateful)
3. Pasarelas de aplicación

Firewalls

1. **Filtrado de paquetes**: las decisiones de filtrado se basan en:
   - Direcciones IP origen y destino
   - Puertos TCP o UDP origen y destino
   - Tipo de mensaje ICMP
   - Cada paquete se analiza de manera independiente a los demás
   - Segmentos de establecimiento de conexión mediante los bits TCP SYN o ACK
   - Políticas restrictivas y permisivas
   - Importancia del "orden" de las sentencias de la lista (desde lo particular a lo general)

Firewalls

2. **Firewalls con estados (stateful):**

- Mantienen un registro de las conexiones a través de los campos del encabezado TCP/IP
- Utilizan tablas dinámicas para seguir el estado en tiempo real de las sesiones end-to-end
- Se permiten paquetes desde el exterior, sólo si la conexión se inició en el interior de la organización
- Registro de direcciones IP y números de puerto en las tablas del firewall

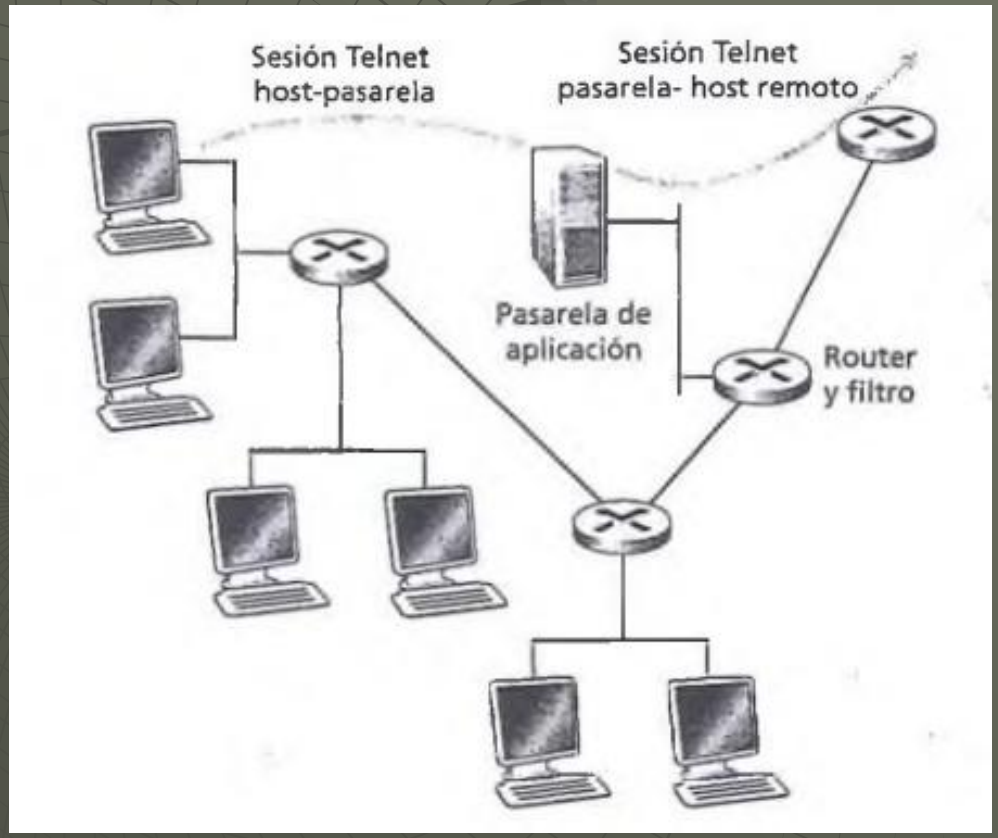
Firewalls

3. **Pasarelas de aplicación:**

- Las decisiones se basan en datos de aplicación
- Permite filtrar según perfiles de usuarios
- Pasarela de aplicación → servidor de aplicación específico a través del cual deben pasar todos los datos (entrantes y salientes)
- Ejemplo: sesión Telnet hacia el exterior de la organización, http, ftp y correo electrónico
- Desventaja → se requiere una pasarela de aplicación para cada aplicación

Firewalls

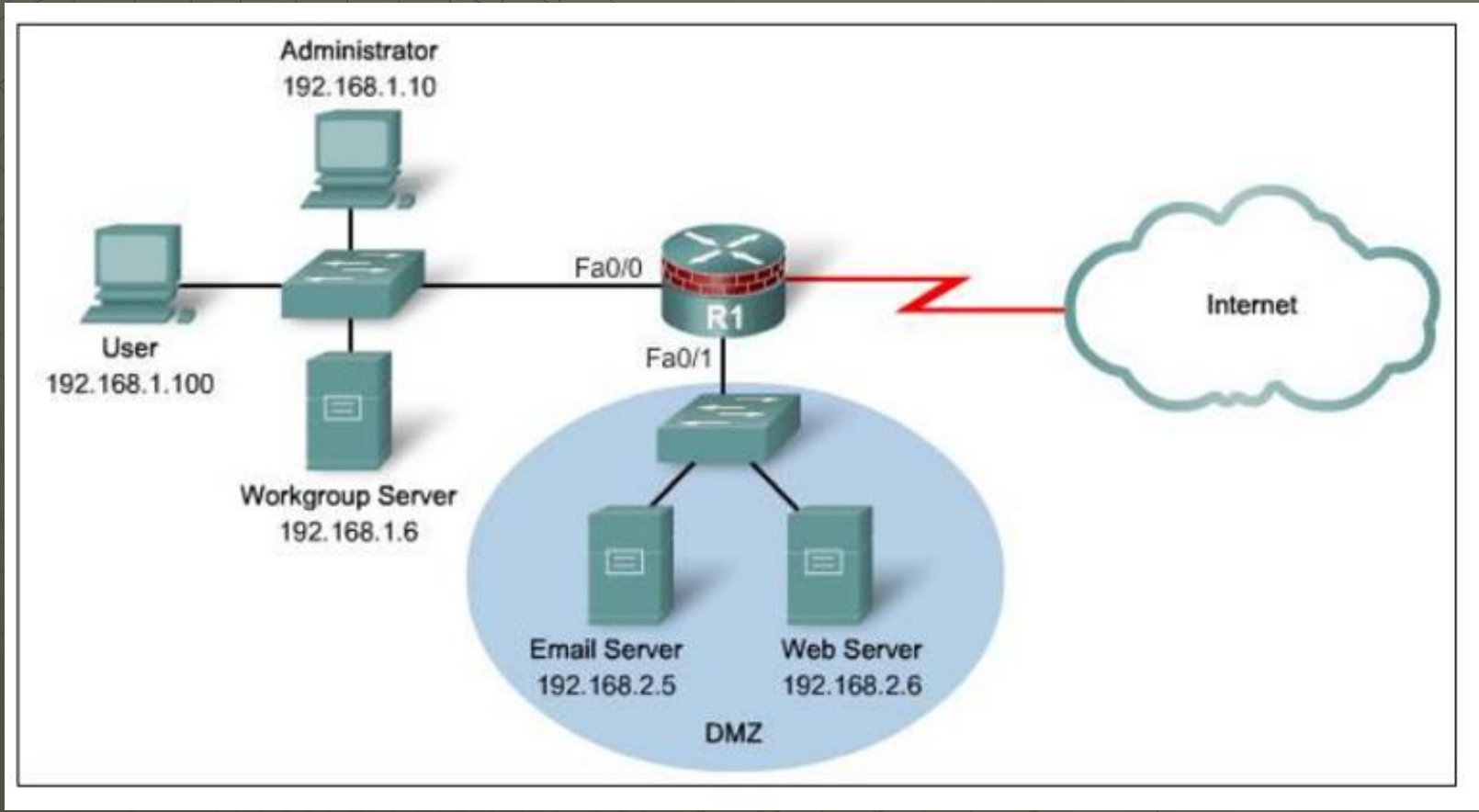
3. **Pasarelas de aplicación:**



DMZ (Zona desmilitarizada)

- Utilizada para los servidores que tienen que ser accesibles desde Internet o alguna otra red externa
- Definen las partes de la red que son confiables y las que no lo son

DMZ (Zona desmilitarizada)



DMZ - Configuración

```
R1(config)# ip access-list extended ACL-1
R1(config-ext-nacl)# remark LAN ACL
R1(config-ext-nacl)# deny ip host 192.168.1.6 any
R1(config-ext-nacl)# permit tcp 192.168.1.0 0.0.0.255 any established
R1(config-ext-nacl)# deny ip any any
R1(config-ext-nacl)# exit
R1(config)# interface Fa0/0
R1(config-if)# ip access-group ACL-1 in
R1(config-if)# exit
R1(config)# ip access-list extended ACL-2
R1(config-ext-nacl)# remark DMZ ACL
R1(config-ext-nacl)# permit tcp any host 192.168.2.5 eq 25
R1(config-ext-nacl)# permit tcp any host 192.168.2.6 eq 80
R1(config-ext-nacl)# deny ip any any
R1(config-ext-nacl)# exit
R1(config)# interface Fa0/1
R1(config-if)# ip access-group ACL-2 out
R1(config-if)# exit
```

De la DMZ a la segmentación interna

- Una red interna “plana” permite que un atacante se mueva libremente una vez adentro (movimiento lateral)
- **Segmentación con VLANs y firewall interno:** usuarios, servidores, telefonía IP, invitados, cámaras / IoT, red industrial (OT)
- **Caso Target (2013):** ingresaron con credenciales de un proveedor de climatización y llegaron a las cajas registradoras → 40 millones de tarjetas robadas
- **Microsegmentación:** reglas entre servidores individuales del datacenter (VMware NSX, Illumio)
- La red de invitados siempre debe estar aislada de la red corporativa

IPsec (IP security)

Características:

- Estándar de seguridad de capa de red
- Framework de estándares abiertos que define reglas para comunicaciones seguras
- Se basa en algoritmos existentes para implementar el cifrado, autenticación e intercambio de claves
- Funciona sobre todos los protocolos de capa 2
- Permite crear paquetes autenticados y confidenciales en el nivel IP
- Servicios principales:
  - Confidencialidad
  - Integridad de datos
  - Autenticación
  - Protección contra ataques de repetición

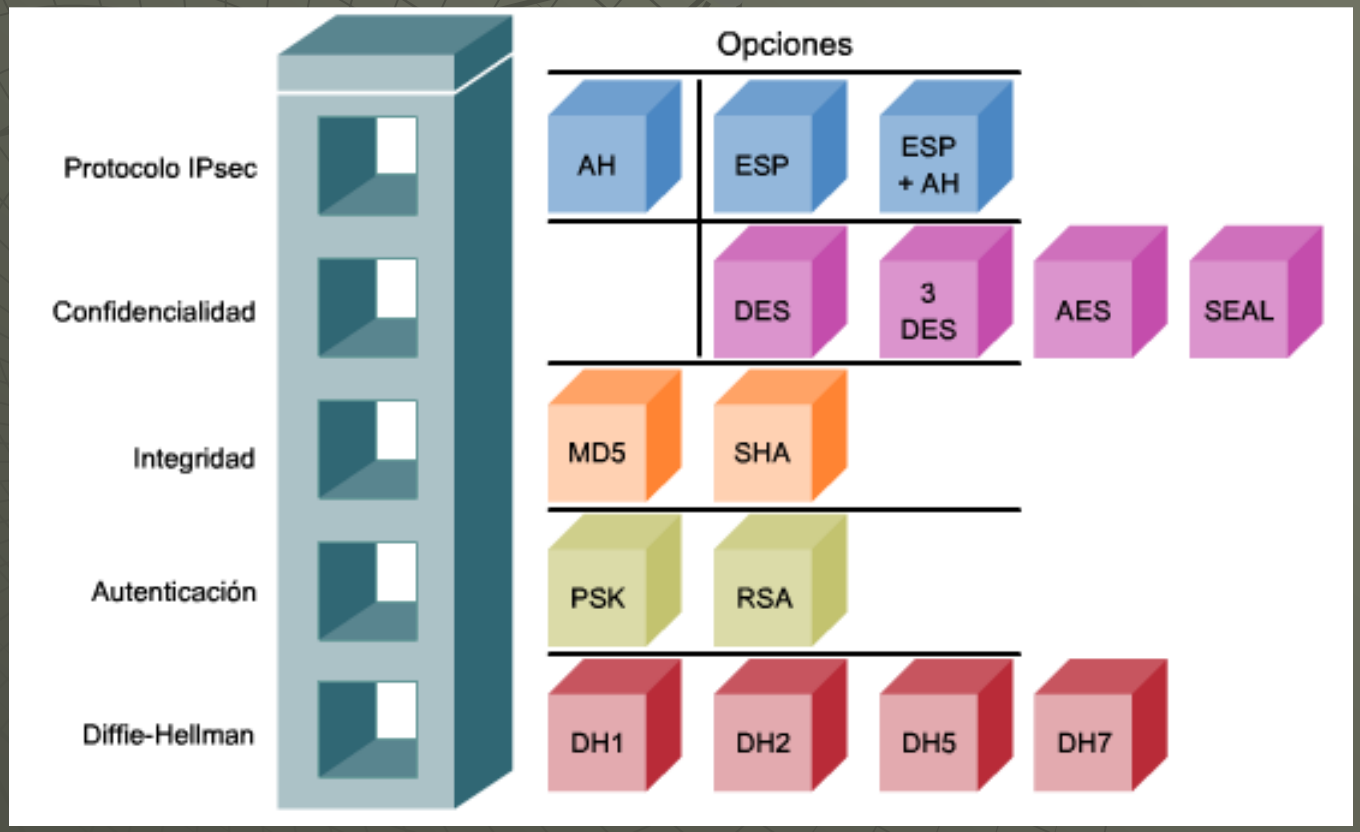
IPsec

Características (cont.):

- Los servicios de basan en criptografía simétrica → alto rendimiento
- IPsec es independiente del algoritmo → esto lo hace escalable
- Es orientado a la conexión
- SA (Asociación de Seguridad) → es una conexión simplex entre dos puntos finales y posee un identificador de seguridad asociado a la conexión (SA)
- Si se requiere tráfico seguro en ambas conexiones → se requieren dos SA

IPsec

- Framework IPsec:



IPsec

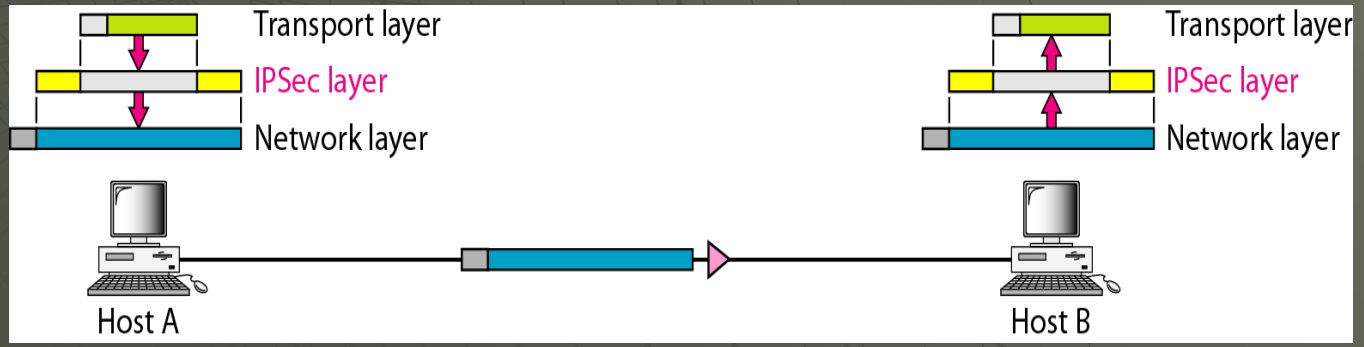
Protocolos IPsec:

- AH (authentication header):
  - Autenticación
  - Integridad
- ESP (encapsulating security payload):
  - Cifrado
  - Autenticación
  - Integridad

IPsec

- Modos de IPsec:

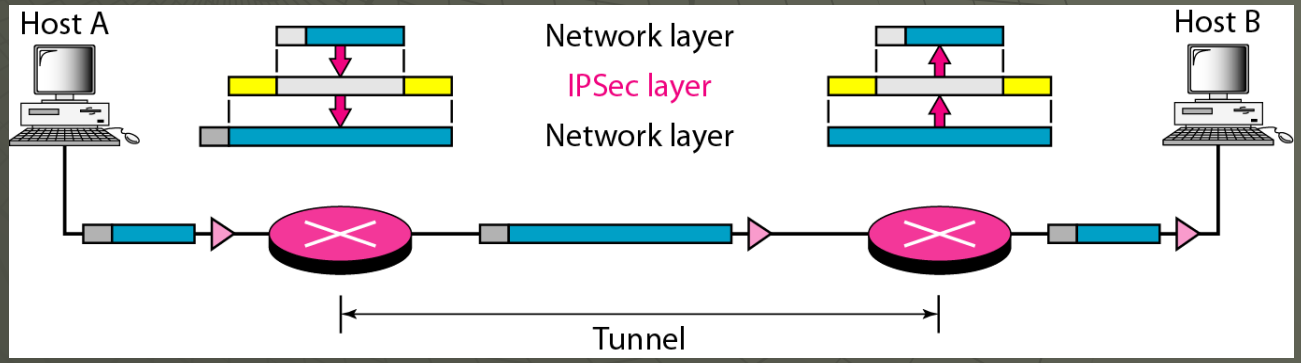
1. Modo de transporte
   - Sólo se autentica o cifra la carga útil del paquete IP
   - El encabezado contiene un identificador SA, un nuevo número de secuencia y una verificación de integridad del campo de carga
   - Utilizado para comunicaciones de PC a PC



IPsec

2. Modo Túnel:

- Todo el paquete IP se encapsula en un nuevo paquete IP con un nuevo encabezado
- Se utiliza cuando el paquete termina en un firewall de una empresa
- El firewall encapsula y desencapsula paquetes
- Las máquinas de la LAN, no son conscientes de la existencia de IPsec
- Inconveniente → agregado de un encabezado IP extra



Redes Privadas Virtuales

VPN (Virtual Private Network)

- Definición: es una red privada que se crea mediante el uso de túneles sobre una red pública, usualmente Internet
- Red Privada
  - Formada por líneas telefónicas alquiladas
  - Alto costo de implementación
  - Muy seguras

Redes Privadas Virtuales

Ventajas de las VPN:

- Costo reducido
  - Las VPN permiten a las organizaciones utilizar Internet para conectar oficinas y usuarios remotos
- Seguridad
  - Utilizan protocolos de cifrado y autenticación
- Escalabilidad
  - Permiten que las empresas se expandan fácilmente utilizando la infraestructura disponible en Internet a través de los ISP
- Facilita la implementación del teletrabajo
  - Permiten que usuarios móviles y trabajadores remotos accedan a las redes corporativas desde cualquier sitio

Redes Privadas Virtuales

- Tipos de VPN:
  - Punto a punto
    - Utilizadas para conexiones entre sucursales y la casa central
  - Acceso Remoto
    - Se aplica en teletrabajo, permitiendo que un empleado acceda a la red de su empresa desde su hogar

Redes Privadas Virtuales

VPN punto a punto:

- Se configura de manera estática
- Conectan redes completas entre sí
- El Gateway de la VPN encapsula y cifra el tráfico saliente de un sitio y lo envía a través del túnel VPN sobre Internet hacia otro gateway VPN
- Ejemplos: Frame Relay, ATM y MPLS

Redes Privadas Virtuales

VPN de acceso remoto

- La VPN se crea de manera dinámica
- Soportan una arquitectura cliente-servidor
- VPN SSL → brinda conectividad de acceso remoto a través de un navegador web y cifrado nativo SSL
- VPN IPsec → permiten acceso seguro a todas las aplicaciones cliente-servidor de la organización

SSL (Secure Sockets Layer) TLS (Transport Layer Security)

Características:

- Proporciona encriptación de datos y autenticación entre un cliente web y un servidor web
- Utilizado ampliamente en el comercio electrónico
- Capa situada entre la capa de aplicación y la de transporte
- En el lado emisor, SSL recibe datos, los encripta y los dirige a un socket TCP
- En el lado receptor, SSL lee del socket TCP, desencripta los datos y los dirige hacia la aplicación
- Características de SSL:
  - Autenticación del servidor
  - Autenticación del cliente
  - Sesión SSL encriptada de toda la información intercambiada

SSL/TLS

Funcionamiento de SSL:

- Un cliente navega por la Web y se conecta a un servidor con capacidades SSL (https)
- Protocolo de Acuerdo SSL:
- Navegador al servidor → versión de su SSL y sus preferencias criptográficas
- Servidor al navegador → versión de su SSL, preferencias criptográficas y su certificado (clave pública RSA del servidor)
- Navegador posee una lista de CA de confianza y la clave pública de cada una de ellas
- Navegador comprueba si la CA se encuentra en su lista. De lo contrario alerta al usuario → no se puede establecer una comunicación segura
- Navegador genera una clave simétrica de sesión, la encripta con la clave pública del servidor y se la envía
- Navegador y Servidor acuerdan cifrar los mensajes con la clave de sesión
- Finaliza el acuerdo SSL y comienza la sesión SSL
- Todos los datos enviados entre el navegador y el servidor se encriptan y desencriptan con la clave de sesión



Gracias por participar!!!